

CardSnap Setup Request for Ali Bhai

Required cloud setup and secure credential handoff for Version 1

Request. Please create or approve the accounts and resources below, then place the required credentials directly in the protected Vercel and GitHub settings. This will allow Haroon and Hassan to complete the live Google Vision and Google Sheets tests. Credentials must not be sent through WhatsApp, chat, browser code or the repository.

Selected services and Version 1 decisions

Decision	Selected approach
1 Login and authentication	CardSnap named accounts using Node script password hashes, server stored sessions, Secure SameSite Strict cookies, CSRF protection, rate limits, lockout and immediate session revocation. No paid identity provider is required.
2 Database and image storage	MongoDB Atlas Free. Contact fields, OCR text and temporary images are encrypted with AES 256 GCM. Images are stored separately in the cardImages collection and never kept in browser storage.
3 Proposed region	Mumbai is the first choice when available for both application compute and Atlas. Keep application and database services in the same geographic area. Ali and Aventure must approve the final region and data residency position.
4 Image retention	24 hours by default. Vision71 administration may set 0 to 168 hours. Zero means no image is saved. The hourly audited sweep is primary and MongoDB TTL is a two hour safety net.
5 Backup and restore	Run an encrypted backup daily through GitHub Actions and retain the encrypted artifact for 30 days. Store it outside Atlas. Restore only into an empty separate database and compare restored collection counts. The automated restore test has passed.
6 Google Sheets connection	Use the Vision71 CardSnap service account through the backend. Share only the selected Sheet as Editor with cardsnap@cardsnap-510210.iam.gserviceaccount.com. Store its JSON private key only in protected environment settings.
7 Aventure API key	Aventure does not need to provide a Google API key. Vision71 supplies the controlled service account. A separate Vision71 Google Vision key is required for OCR and must be restricted to Cloud Vision only.
8 Version 1 workflow	CardSnap capture, Aventure owned Google Sheet, Hala reviews with a status dropdown, Approved rows are exported as CSV, then Aventure or Vision71 manually imports the approved contacts into the agreed Constant Contact list. There is no automatic Constant Contact connection.

Current status

Complete: private staging deployment from haroon, named test accounts, roles, encrypted storage, audit controls, retention, backup and restore, protected OCR logic, Sheet mapping and status sync, Approved CSV export, 112 passing automated tests and a passing production build.

Setup Steps and Internal Test Plan

Actions required before Ali Bhai's staging review

Setup steps for Ali Bhai

1. MongoDB Atlas. Create or confirm one Free cluster, select the approved region, create the cardsnap_vision71_staging database and create a database user restricted to that database. Configure the network allowlist for Vercel after reviewing the lack of fixed Vercel outbound addresses. Place MONGODB_URI directly in Vercel and the approved local environment.
2. Google Cloud. Use project cardsnap-510210, enable the Google Sheets API and Cloud Vision API, and confirm the service account cardsnap@cardsnap-510210.iam.gserviceaccount.com is enabled.
3. Service account credential. Create a JSON key for the CardSnap service account. Place client_email as GOOGLE_SERVICE_ACCOUNT_EMAIL and private_key as GOOGLE_SERVICE_ACCOUNT_PRIVATE_KEY directly in Vercel. Do not send the JSON file through chat or commit it.
4. Google Sheet. For internal testing, share the Vision71 test Sheet with the service account as Editor. For live use, Aventure creates or copies the approved template into its own Drive and shares only that Sheet. Set the approved Sheet URL or identifier in the protected environment.
5. Google Vision. Revoke the key previously exposed in chat. Create a replacement restricted to Cloud Vision only and place it directly in Vercel as GOOGLE_VISION_API_KEY. CardSnap sends it in the X Goog Api Key header and never in a URL.
6. Backup and sweep. Add APP_BASE_URL, CRON_SECRET, MONGODB_URI and BACKUP_KEY to GitHub Actions. Confirm BACKUP_KEY differs from ENCRYPTION_KEY.
7. Final integration. Haroon and Hassan run the Sheet configuration command, submit fake records, confirm Hala's status updates return to CardSnap, test Approved CSV export, run mobile checks and record the short demonstration video.

Secure values required

- MONGODB_URI for the restricted CardSnap database user
- GOOGLE_SERVICE_ACCOUNT_EMAIL and GOOGLE_SERVICE_ACCOUNT_PRIVATE_KEY
- A replacement GOOGLE_VISION_API_KEY restricted to Cloud Vision only
- The approved Google Sheet URL or identifier and tab identifier
- CRON_SECRET, ENCRYPTION_KEY and a different BACKUP_KEY

Handoff method. Ali Bhai should enter these values directly in the Vercel and GitHub secret settings or use an approved one time secret manager. Haroon and Hassan need access to use the configured values, not copies stored in messages or files.

Internal testing dates owners and evidence

Date	Owner	Required evidence
1 October 2026	Ali Bhai with Haroon and Hassan	Cloud accounts, restricted identities and environment names visible in provider settings. No secret values in screenshots.
2 October 2026	Haroon and Hassan	Live Google Vision and Sheet write tests using fake contacts, captured request results and audit references.
3 to 4 October 2026	Zaid and Ibrahim as Capturers, Hala as Reviewer	Capture, duplicate, missing field, correction, approval, rejection, failed Sheet retry and removed user results in the test report.
5 October 2026	Haroon and Hassan	Mobile capture and review evidence, Approved CSV, backup restore evidence and short demonstration video.
6 October 2026	Ali Bhai	Private staging review against the security checklist and recorded approval or required changes.

Proposed staging review: 6 October 2026. This date depends on the protected credentials and Sheet access being configured by 1 October 2026.

CardSnap Version 1 One Page Recommendation

Decision owner Ali Bhai | Internal testing followed by the first Aventure exhibition

Status: Recommendation only. No production resource should be created until written approval.

Area	Recommendation
Login and authentication	Use the CardSnap named account system already implemented. It uses Node script password hashes, server stored sessions, Secure and SameSite Strict cookies, CSRF protection, sign in rate limits, account lockout, eight hour maximum sessions, thirty minute idle expiry and immediate session revocation when an account is removed. Vision71 creates the initial named accounts. Hala reviews in the Sheet and does not need a CardSnap login for Version 1.
Database	Use a dedicated MongoDB Atlas Free database for internal testing. Keep every tenant separate and encrypt contact fields, OCR text and images in the application with AES 256 GCM. Use a database user restricted to the CardSnap database. Atlas Free has a 512 MB limit, no automatic backups and no database audit, so usage monitoring, application audit records and external encrypted backups are required.
Image storage	Store compressed images temporarily in the encrypted MongoDB cardImages collection for Version 1. Do not create Google Cloud Storage or another production storage resource until Ali approves it. Images must not remain in browser storage.
Cloud provider and region	Keep the application in a separate Vercel staging project. For the live pilot, propose a region near the operating team, with Mumbai as the first choice if it is available for both application compute and Atlas. Keep the application and database in the same geographic area where possible. Ali and Aventure must approve the final region and data residency position before live data is used.
Retention and deletion	Use a default card image retention period of 24 hours, configurable from 0 to 168 hours by Vision71 administration. A value of 0 prevents image storage. Run the audited deletion sweep every hour and use the MongoDB TTL index as a two hour safety net. Contact records remain until an approved deletion request or the agreed end of pilot deletion.
Backup method	Run the Node backup script daily through GitHub Actions. Export cards, users without password hashes, lists and settings. Exclude images, sessions, login attempts, rate limits and tokens. Compress and encrypt each backup with a separate 32 byte backup key, retain the encrypted artifact for 30 days and perform a documented restore test after material storage changes.
Expected monthly cost	Expected internal test cost is 0 USD while usage remains inside approved free allowances. This assumes MongoDB Atlas Free, existing GitHub Actions allowance and Google Vision usage within its approved allowance. Vercel Hobby is restricted to non commercial use, so it must not be treated as an approved commercial production plan. Google Cloud billing requirements and the live hosting cost must be confirmed before the pilot. Stop before enabling any resource that requires an unapproved payment method or charge.
Who can access the data	Capturers can submit contacts and view or correct only their own records. Hala can view and update the protected Aventure owned Sheet. Vision71 Administrators can manage named users, retention, deletion and Approved CSV export. Vision71 Support can view aggregate counts only, cannot browse contact details or images and expires after 24 hours. The backend service account can access only the approved Sheet. Constant Contact receives data only through the approved manual CSV import in Version 1.

Approval points

Ali and Aventure must approve the final cloud region, live hosting plan, Atlas network access, image retention period, Google service account access, Aventure owned Sheet and any expected charge before real Aventure data is used.